

# **CCNA 200-301 Yerel Ağ Güvenliği**

- Uç Nokta Güvenliği
- Erişim Kontrolü
- Layer 2 Güvenlik Tehditleri
- MAC Adres Tablosu Saldırısı
- VLAN Saldırıları
- Port Güvenliği Yapılandırması
- VLAN Saldırılarını Azaltma-Önleme
- DHCP Saldırılarını Azaltma
- ARP Saldırılarını Azaltma
- STP Saldırılarını Önleme

# Uç Nokta Güvenliği

## Günümüzde Ağ Saldırıları

Günümüzde hemen hemen her gün yazılı, görsel veya internet medyasında ağ saldırıları hakkında haberler izliyoruz/okuyoruz. Sıklıkla yaşanan ağ saldırılarını aşağıdaki şekilde özetlemek mümkün.

- **Distributed Denial of Service – Dağıtılmış Hizmet Reddi (DDoS)** – Bu, bir kuruluşun web sitesine ve kaynaklarına erişimi azaltmak veya durdurmak amacıyla, zombi adı verilen birçok cihazdan gelen koordineli bir saldırıdır.
- **Data Breach – Veri İhlali** – Bir kuruluşun veri sunucularının veya bilgisayarlarının gizli bilgileri çalmak için tehlikeye atıldığı bir saldırıdır.
- **Malware-Zararlı Yazılım** – Bir kuruluşun bilgisayarlarına çeşitli sorunlara neden olan kötü yazılımlardan etkilenen bir saldırıdır. Örneğin, WannaCry gibi fidye yazılımı, bir bilgisayardaki verileri şifreler ve bir fidye ödenene kadar ona erişimi kilitler.

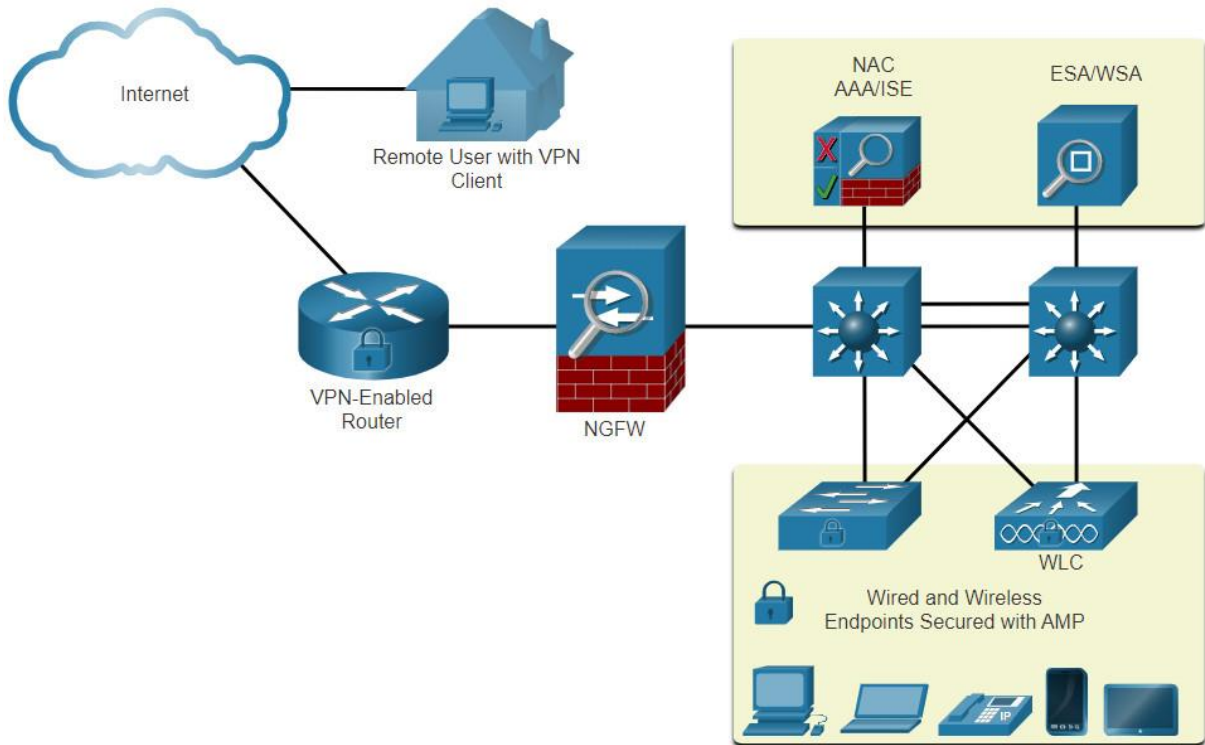
## Ağ Güvenliği Cihazları

Ağ çevresini dış erişimden korumak için çeşitli ağ güvenlik cihazları gerekir. Bu cihazlar aşağıdakileri içerebilir:

- **Virtual Private Network (VPN) enabled router (Sanal Özel Ağ (VPN) etkin yönlendirici)** – Bir genel ağdaki ve kurumsal ağdaki uzak kullanıcılara güvenli bağlantı sağlar. VPN hizmetleri güvenlik duvarına entegre edilebilir.
- **Next Generation Firewall (NGFW)** – Durum bilgisi olan paket denetimi, uygulama görünürlüğü ve kontrolü, yeni nesil saldırı önleme sistemi (NGIPS), gelişmiş kötü amaçlı yazılım koruması (AMP) ve URL filtreleme sağlar.
- **Network Access Control (NAC)** – Kimlik doğrulama, yetkilendirme ve hesap yönetimi (AAA) hizmetlerini içerir. Daha büyük işletmelerde, bu hizmetler çok çeşitli kullanıcılar ve cihaz türlerine erişim politikalarını yönetebilen bir cihaza dahil edilebilir. Cisco Identity Service Engine (ISE), bir NAC cihazına örnektir.

## Uç Nokta Koruması

- Uç noktalar, genellikle dizüstü bilgisayarlardan, masaüstü bilgisayarlardan, sunuculardan ve IP telefonlardan ve ayrıca çalışanların sahip olduğu cihazlardan oluşan ana makinelerdir. Uç noktalar özellikle e-posta veya web'de gezinme kaynaklı kötü amaçlı yazılımlarla ilgili saldırılara açıktır.
- Uç noktalar genellikle virüsten koruma / kötü amaçlı yazılımdan koruma, ana bilgisayar tabanlı güvenlik duvarları ve ana bilgisayar tabanlı saldırı önleme sistemleri (HIPS) gibi geleneksel ana bilgisayar tabanlı güvenlik özelliklerini kullanmıştır.
- Bugün uç noktalar en iyi NAC, AMP yazılımı, e-posta güvenlik cihazı (ESA) ve web güvenlik cihazı (WSA) kombinasyonu ile korunmaktadır.



## Cisco Email Security Appliance

Cisco ESA cihazı, Simple Mail Transfer Protocol (SMTP) 'ünü izlemek için tasarlanmıştır. Cisco ESA, dünya çapında bir veri tabanı izleme sistemi kullanarak tehditleri ve çözümleri tespit eden ve ilişkilendiren Cisco Talos'un gerçek zamanlı beslemeleriyle sürekli güncellenir. Bu tehdit istihbarat verileri, her üç ila beş dakikada bir Cisco ESA tarafından alınır.

Cisco ESA'nın bazı işlevleri şunlardır:

- Bilinen tehditleri engelleme
- İlk tespitten kaçan gizli kötü amaçlı yazılımlara karşı çözüm
- Kötü bağlantıları olan e-postaları silme
- Yeni virüs bulaşmış sitelere erişimi engelleme
- Veri kaybını önlemek için giden e-postadaki içeriği şifreleme

## Cisco Web Security Appliance

- Cisco Web Güvenlik Cihazı (WSA), web tabanlı tehditler için bir önleme teknolojisidir. Kuruluşların web trafiğini güvence altına alma ve kontrol etme zorluklarını çözmelerine yardımcı olur.
- Cisco WSA, gelişmiş kötü amaçlı yazılım koruması, uygulama görünürlüğü ve kontrolü, kabul edilebilir kullanım politikası kontrolleri ve raporlamayı birleştirir.
- Cisco WSA, kullanıcıların internete nasıl eriştiği üzerinde tam kontrol sağlar. Kuruluşun gereksinimlerine göre sohbet, mesajlaşma, video ve ses gibi belirli özelliklere ve uygulamalara izin verilebilir, zaman ve bant genişliği sınırları ile kısıtlanabilir veya engellenebilir.
- WSA, URL'lerin kara listeye alınması, URL filtreleme, kötü amaçlı yazılım taraması, URL kategorizasyonu, Web uygulaması filtrelemesi ve web trafiğinin şifrenmesi ve şifresinin çözülmesi işlemlerini gerçekleştirebilir.

# Erişim Kontrolü

## Yerel Parola ile Kimlik Doğrulama

Ağ aygıtlarında birçok kimlik doğrulama türü gerçekleştirilebilir ve her yöntem farklı düzeylerde güvenlik sunar.

Uzaktan erişim kimlik doğrulamasının en basit yöntemi konsol, vty hatları ve aux bağlantı noktalarında bir oturum açma adı ve parola birleşimi yapılandırmasıdır.

```
R1(config)# line vty 0 4
R1(config-line)# password ci5c0
R1(config-line)# login
```

SSH daha güvenli bir uzaktan erişim biçimidir:

- Bir kullanıcı adı ve şifre gerektirir.
- Kullanıcı adı ve parola yerel olarak doğrulanabilir.

```
R1(config)# ip domain-name example.com
R1(config)# crypto key generate rsa general-keys modulus 2048
R1(config)# username Admin secret Str0ng3rPa55w0rd
R1(config)# ssh version 2
R1(config)# line vty 0 4
R1(config-line)# transport input ssh
R1(config-line)# login local
```

Yerel veri tabanı yönteminin bazı sınırlamaları vardır:

- Kullanıcı hesapları ölçeklenemeyen her cihazda yerel olarak yapılandırılmalıdır.
- Yöntem, yedek kimlik doğrulama yöntemi sağlamaz.

## AAA Bileşenleri

**AAA**, Kimlik Doğrulama (**Authentication**), Yetkilendirme (**Authorization**) ve Hesap Yönetimi – Muhasebe (**Accounting**) anlamına gelir ve bir ağ cihazında erişim kontrolü kurmak için birincil çerçeve sağlar.

AAA, bir ağa kimin erişmesine izin verildiğini (kimlik doğrulaması), oradayken neler yapabileceği (yetkilendirme) ve ağa erişirken yaptıkları işlemleri (muhasebe) denetlemenin bir yoludur.

## Authentication – Kimlik Doğrulama

Yerel ve sunucu tabanlı, AAA kimlik doğrulamasını uygulamanın iki yaygın yöntemidir.

### Local AAA Authentication:

- Yöntem, kullanıcı adlarını ve parolalarını yerel olarak bir ağ aygıtında (ör. Cisco yönlendirici) depolar.
- Kullanıcılar yerel veri tabanında kimlik doğrulaması yapar.
- Yerel AAA, küçük ağlar için idealdir.

### Server-Based AAA Authentication:

- Sunucu tabanlı yöntemle yönlendirici merkezi bir AAA sunucusuna erişir.
- AAA sunucusu tüm kullanıcılar için kullanıcı adları ve parolaları içerir.
- Yönlendirici, AAA sunucusuyla iletişim kurmak için Uzaktan Kimlik Doğrulama İçeri Arama Kullanıcı Hizmeti – Remote Authentication Dial-In User Service (RADIUS) veya Terminal Erişim Denetleyicisi Erişim Kontrol Sistemi – Terminal Access Controller Access Control System (TACACS+) protokollerini kullanır.
- Birden fazla yönlendirici ve anahtar olduğunda, sunucu tabanlı AAA daha uygundur.

## Authorization – Yetkilendirme

AAA yetkilendirmesi otomatiktir ve kullanıcıların kimlik doğrulamasından sonra ek adımlar gerçekleştirmelerini gerektirmez.

Yetkilendirme, kullanıcıların kimliği doğrulandıktan sonra ağda yapabileceklerini ve yapamayacaklarını yönetir.

Yetkilendirme, kullanıcının ağa erişimini açıklayan bir dizi özellik kullanır. Bu özellikler, AAA sunucusu tarafından o kullanıcının ayrıcalıklarını ve kısıtlamalarını belirlemek için kullanılır.

## Accounting – Hesap Yönetimi (Muhasebe)

AAA muhasebesi kullanım verilerini toplar ve raporlar. Bu veriler denetim veya faturalandırma gibi amaçlar için kullanılabilir. Toplanan veriler, başlatma ve durdurma bağlantı sürelerini, yürütülen komutları, paket sayısını ve bayt sayısını içerebilir.

Muhasebenin birincil kullanımı, AAA kimlik doğrulaması ile birleştirmektir.

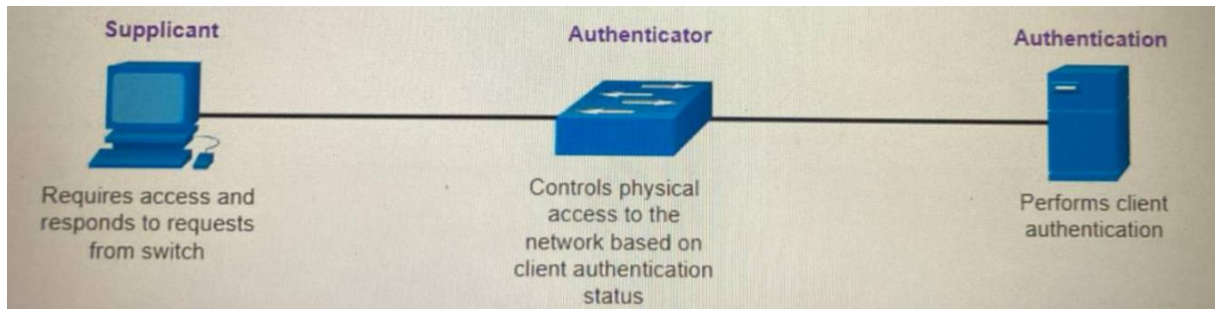
- AAA sunucusu, kimliği doğrulanmış kullanıcının cihazda tam olarak ne yaptığını gösteren ayrıntılı bir günlük tutar. Bu, kullanıcı tarafından verilen tüm EXEC ve yapılandırma komutlarını içerir.
- Günlük, kullanıcı adı, tarih, saat ve kullanıcı tarafından girilen gerçek komut dahil çok sayıda veri alanı içerir. Bu bilgiler aygıtlarla ilgili sorunları giderirken yararlıdır. Ayrıca bireylerin ne zaman kötü niyetli davranışlarda bulunduğuna dair kanıt sağlar.

## 802.1X

IEEE 802.1X standardı, bağlantı noktası tabanlı bir erişim denetimi ve kimlik protokolüdür. Bu protokol, yetkisiz iş istasyonlarının genele açık anahtar bağlantı noktaları üzerinden LAN'a bağlanmasını kısıtlar. Kimlik doğrulama sunucusu, anahtar veya LAN tarafından sunulan hizmetleri sunmadan önce bir anahtar bağlantı noktasına bağlı her iş istasyonunun kimliğini doğrular.

802.1X bağlantı noktası tabanlı kimlik doğrulamasıyla, ağdaki cihazların belirli rolleri vardır:

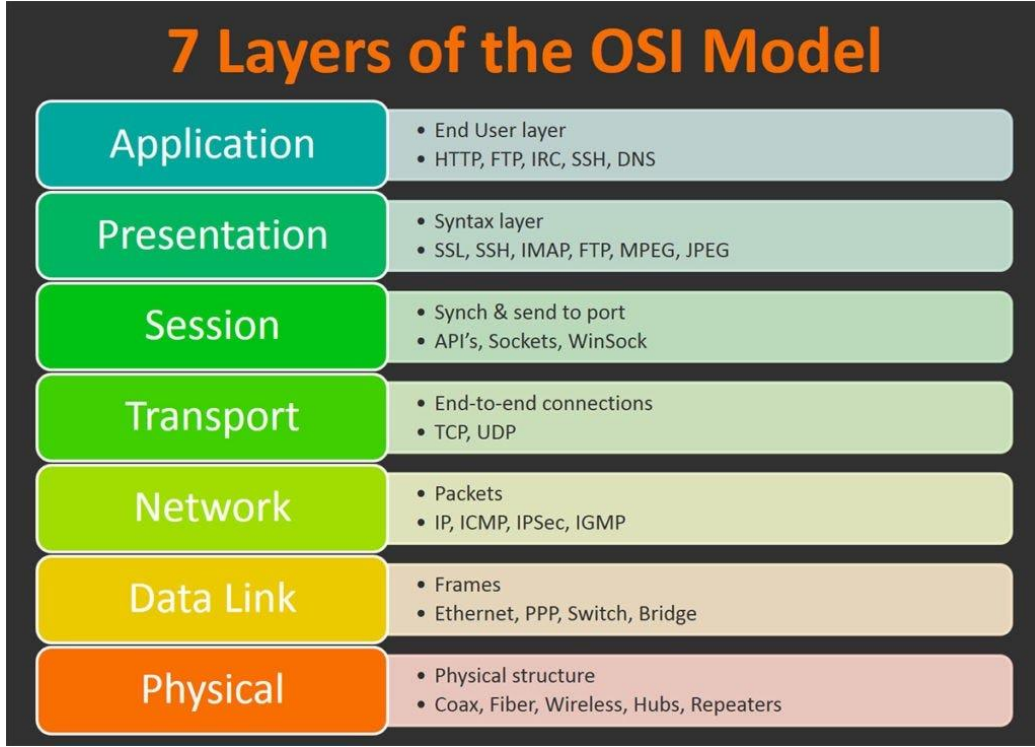
- **Client (Supplicant)** – Bu, kablolu veya kablosuz aygıtlar için kullanılabilen 802.1X uyumlu istemci yazılımı çalıştıran bir aygıttır.
- **Switch (Authenticator)** – Anahtar, istemci ile kimlik doğrulama sunucusu arasında aracı görevi görür. İstemciden kimlik tanımlamayı ister, bu bilgileri kimlik doğrulama sunucusuyla doğrular ve istemciye bir yanıt iletir. Kimlik doğrulayıcı olarak işlev görebilen başka bir aygıt, kablosuz erişim noktasıdır.
- **Authentication server** – Sunucu, istemcinin kimliğini doğrular ve istemcinin LAN'a ve geçiş hizmetlerine erişme yetkisi olduğunu veya yetkilendirilmediğini anahtar veya kablosuz erişim noktasına bildirir.



# Layer 2 Güvenlik Tehditleri

## Katman 2 Güvenlik Açıkları

OSI referans modelinin birbirinden bağımsız çalışan yedi katmana ayrıldığını hatırlayın. Şekilde her katmanın işlevi ve yararlanılabilecek çekirdek öğeler gösterilmektedir.



Ağ yöneticileri, Katman 3'teki öğeleri Katman 7 aracılığıyla korumak için rutin olarak güvenlik çözümleri uygularlar. Bu öğeleri korumak için VPN'ler, güvenlik duvarları ve IPS aygıtları kullanırlar. Bununla birlikte, Katman 2'den ödün verilirse, üstündeki tüm katmanlar da etkilendir. Örneğin, dahili ağa erişimi olan bir tehdit aktörü Katman 2 çerçevelerini (frame) yakaladıysa, yukarıdaki katmanlarda uygulanan tüm güvenlik işe yaramaz. Tehdit aktörü Katman 2 LAN ağ altyapısında çok fazla hasara neden olabilir.

## Switch Saldırı Kategorileri

Güvenlik yalnızca sistemdeki en zayıf halka kadar güçlüdür ve Katman 2 de bu zayıf halka olarak kabul edilir. Bunun nedeni, LAN'ların geleneksel olarak tek bir kuruluşun idari kontrolü altında olmasıdır. LAN'ımıza bağlı olan tüm kişilere ve cihazlara doğal olarak güvendik. Bugün, BYOD (Bring Your Own Device) ve daha karmaşık saldırılarla, LAN'larımız sızmaya karşı daha savunmasız hale geldi.

| Category                        | Examples                                                                                                                        |
|---------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| <b>MAC Table Attacks</b>        | MAC adresi taşıma saldırılarını içerir.                                                                                         |
| <b>VLAN Attacks</b>             | VLAN atlaması ve VLAN çift etiketleme saldırılarını içerir. Ayrıca ortak bir VLAN'daki cihazlar arasında saldırıları da içerir. |
| <b>DHCP Attacks</b>             | DHCP açlığı ve DHCP kimlik sahtekarlığı saldırılarını içerir.                                                                   |
| <b>ARP Attacks</b>              | ARP kimlik sahtekarlığı ve ARP zehirlenmesi saldırılarını içerir.                                                               |
| <b>Address Spoofing Attacks</b> | MAC adresi ve IP adresi kimlik sahtekarlığı saldırılarını içerir.                                                               |
| <b>STP Attacks</b>              | STP manipölasyon saldırılarını içerir.                                                                                          |

## Switch Saldırı Azaltma Teknikleri

| Solution                     | Description                                                                               |
|------------------------------|-------------------------------------------------------------------------------------------|
| Port Security                | MAC adresi taşıma saldırıları ve DHCP açlık saldırıları gibi birçok saldırı türünü önler. |
| DHCP Snooping                | DHCP açlık ve DHCP sahtekarlığı saldırılarını önler.                                      |
| Dynamic ARP Inspection (DAI) | ARP sahtekarlığı ve ARP zehirlenme saldırılarını önler.                                   |
| IP Source Guard (IPSG)       | MAC ve IP adresi kimlik sahtekarlığı saldırılarını önler.                                 |

Yönetim Protokolleri güvenli değilse bu Katman 2 çözümleri etkili olmayacaktır. Aşağıdaki stratejiler önerilir:

- Her zaman SSH, Güvenli Kopya Protokolü (SCP-Secure Copy Protocol), Güvenli FTP (SFTP) ve Güvenli Yuva Katmanı / Aktarım Katmanı Güvenliği (SSL / TLS-Secure Socket Layer / Transport Layer Security) gibi güvenli yönetim protokolleri çeşitlerini kullanın.
- Cihazları yönetmek için bant dışı yönetim ağını kullanmayı düşünün (konsol bağlantısı).
- Yönetim trafiğinden başka hiçbir şeyin bulunmadığı özel bir yönetim VLAN'ı kullanın.
- İstenmeyen erişimi filtrelemek için ACL'leri kullanın.

# MAC Adres Tablosu Saldırısı

## Switch Nasıl Çalışır

Yönlendirme kararları vermek için Katman 2 LAN anahtarının alınan çerçevelerdeki kaynak MAC adreslerine dayalı bir tablo oluşturduğunu hatırlayın. Buna MAC adres tablosu denir. MAC adres tabloları bellekte saklanır ve çerçeveleri daha etkin bir şekilde iletmek için kullanılır.

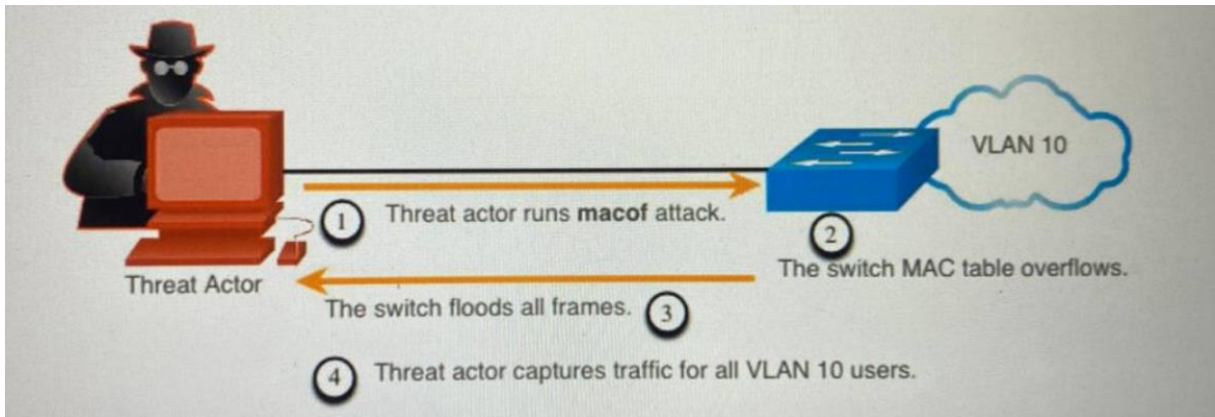
```
S1# show mac address-table dynamic
Mac Address Table
-----
Vlan    Mac Address      Type      Ports
----    -
1       0001.9717.22e0   DYNAMIC   Fa0/4
1       000a.f38e.74b3   DYNAMIC   Fa0/1
1       0090.0c23.ceca   DYNAMIC   Fa0/3
1       00d0.ba07.8499   DYNAMIC   Fa0/2
S1#
```

## MAC Adres Tablosu Taşıma Saldırısı

Tüm MAC tabloları sabit bir boyuta sahiptir ve sonuç olarak, bir anahtar MAC adreslerinin depolanacağı kaynaklar tükenebilir. MAC adresi sel saldırıları, anahtar MAC adres tablosu dolana kadar anahtarı sahte kaynak MAC adresleriyle bombalayarak bu sınırlamadan yararlanır.

Bu durumda, anahtar çerçeveye bilinmeyen bir tek noktaya yayın olarak davranır ve MAC tablosuna başvurmadan gelen tüm trafiği aynı VLAN'daki tüm bağlantı noktalarından taşımaya başlar. Bu koşul artık bir tehdit aktörünün yerel LAN'da veya yerel VLAN'da bir ana bilgisayardan diğerine gönderilen tüm çerçeveleri yakalamasına izin verir.

Not: Trafik yalnızca yerel LAN veya VLAN içinde taşar. Tehdit aktörü yalnızca tehdit aktörünün bağlı olduğu yerel LAN veya VLAN içindeki trafiği yakalayabilir.



## MAC Adres Tablosu Saldırılarını Azaltma

Macof gibi araçları bu kadar tehlikeli yapan şey, bir saldırganın çok hızlı bir şekilde MAC tablosu taşma saldırısı oluşturabilmesidir. Örneğin, bir Catalyst 6500 Switch, MAC adres tablosunda 132.000 MAC adresi saklayabilir. Macof gibi bir araç, saniyede 8.000 sahte çerçeveye sahip bir sel oluşturabilir ve birkaç saniye içinde bir MAC adres tablosu taşma saldırısı oluşturabilir.

Bu saldırı araçlarının tehlikeli olmasının bir başka nedeni, yalnızca yerel anahtarı etkilemekle kalmaz, aynı zamanda diğer bağlı Katman 2 anahtarlarını da etkileyebilir. Bir anahtarın MAC adres tablosu dolduğunda, diğer Katman 2 anahtarına bağlı olanlar da dahil olmak üzere tüm bağlantı noktalarına taşmaya başlar.

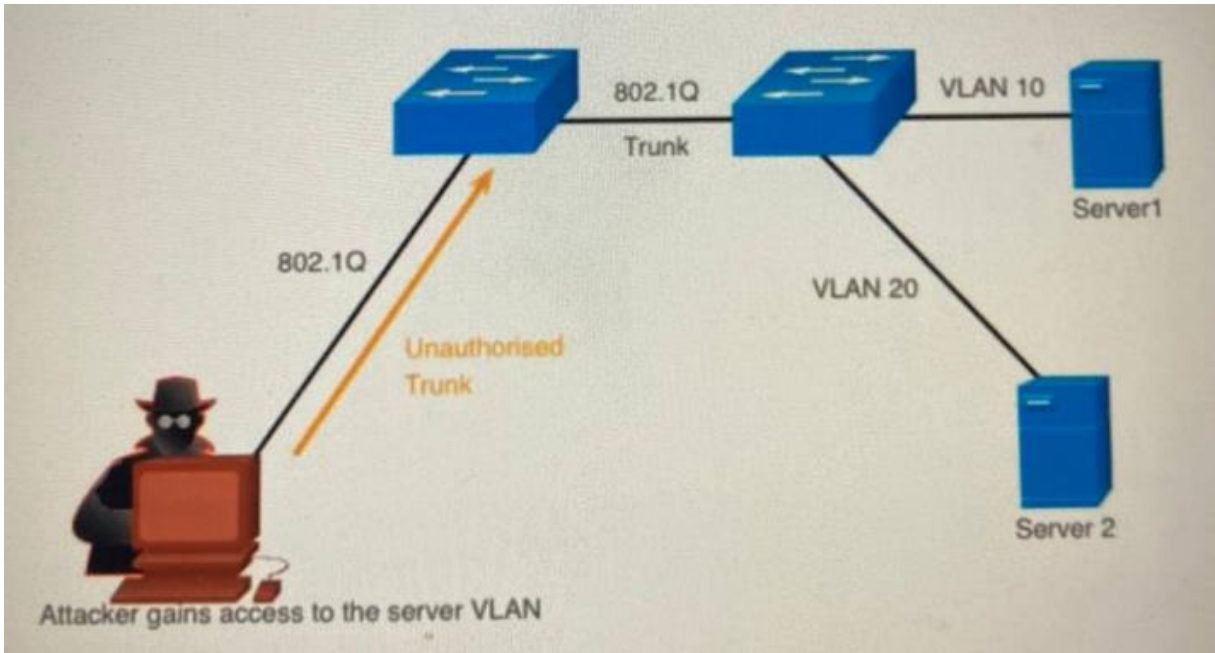
MAC adres tablosu taşma saldırılarını azaltmak için ağ yöneticilerinin **bağlantı noktası güvenliği (Port Security)** uygulaması gerekir. Bağlantı noktası güvenliği, bağlantı noktasında yalnızca belirtilen sayıda kaynak MAC adresinin öğrenilmesine izin verir.

# LAN Saldırıları

## VLAN Atlama Saldırıları

Bir VLAN atlama saldırısı, bir yönlendiricinin yardımı olmadan bir VLAN'dan gelen trafiğin başka bir VLAN tarafından görülmesini sağlar. Temel bir VLAN atlama saldırısında, tehdit aktörü, çoğu anahtar bağlantı noktasında varsayılan olarak etkinleştirilen otomatik kanal bağlantı noktası özelliğinden (DTP) yararlanmak için bir ana bilgisayar anahtar gibi davranacak şekilde yapılandırılır.

Tehdit aktörü, ana bilgisayar bağlantı anahtarı ile devre dışı bırakmak için 802.1Q sinyalleme ve Cisco'ya özel Dinamik Kanal Protokolü (DTP) sinyalini taklit edecek şekilde yapılandırılır. Başarılı olursa, anahtar şekilde gösterildiği gibi ana bilgisayar ile bir devre bağlantısı kurar. Artık tehdit aktörü anahtardaki tüm VLAN'lara erişebilir. Tehdit aktörü, VLAN'lar arasında etkili bir şekilde atlayarak herhangi bir VLAN'a trafik gönderebilir ve alabilir.

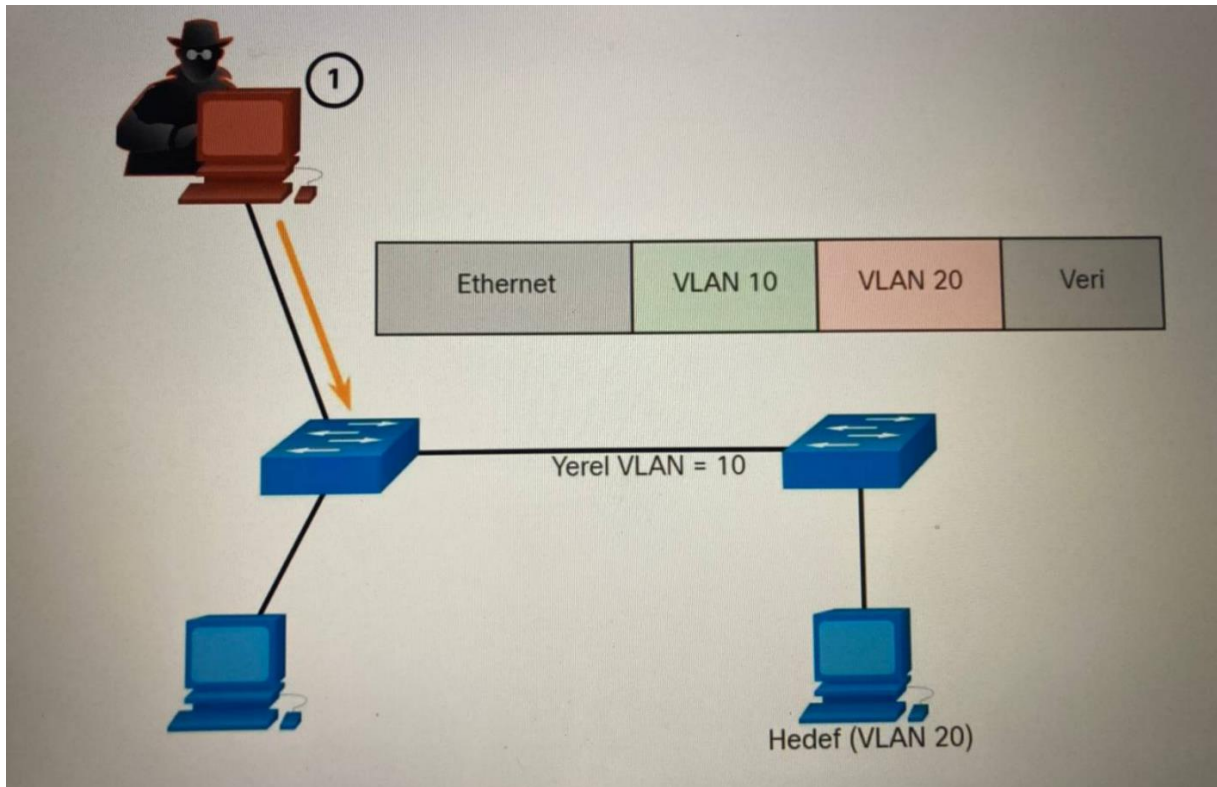


## VLAN Çift Etiketleme Saldırıları

Bir tehdit aktörü, 802.1Q etiketi olan çerçevenin içine gizli bir 802.1Q etiketini yerleştirebilir. Bu etiket, çerçevenin orijinal 802.1Q etiketinin belirtmediği bir VLAN'a gitmesine izin verir.

- Adım 1: Tehdit aktörü anahtara çift etiketli bir 802.1Q çerçevesini gönderir. Dış başlıkta, tehdit bağlantı noktasının ana bağlantı noktasının yerel VLAN'ı (Native Vlan) ile aynı olan VLAN etiketi bulunur.

- Adım 2: Çerçeve, ilk 4 baytlık 802.1Q etiketine bakan ilk anahtara gelir. Anahtar, çerçevenin yerel VLAN için hedeflendiğini görür. Anahtar, VLAN etiketini çıkardıktan sonra paketi tüm yerel VLAN bağlantı noktalarından iletir. Çerçeve, yerel VLAN'ın bir parçası olduğu için yeniden etiketlenmez. Bu noktada, iç VLAN etiketi hala sağlamdır ve ilk anahtar tarafından denetlenmemiştir.
- Adım 3: Çerçeve, yerel VLAN için olması gerektiğini bilmeyen ikinci anahtara gelir. Yerel VLAN trafiği, 802.1Q protokolünde belirtildiği gibi gönderen anahtar tarafından etiketlenmez. İkinci anahtar yalnızca tehdit aktörünün eklediği iç 802.1Q etiketine bakar ve çerçevenin hedef VLAN'a yönlendirildiğini görür. İkinci anahtar, hedef için mevcut bir MAC adres tablosu girişi olup olmasına bağlı olarak çerçeveyi hedefe gönderir veya taşırır.



Bir VLAN çift etiketleme saldırısı tek yönlüdür ve yalnızca saldırgan, ana bağlantı noktasının yerel VLAN'ıyla aynı VLAN'da bulunan bir bağlantı noktasına bağlandığında çalışır. Buradaki fikir, çift etiketlemenin, saldırganın bir tür erişim kontrolü yapılandırması tarafından engellenecek bir VLAN üzerindeki ana bilgisayarlara veya sunuculara veri göndermesine izin vermesidir. Muhtemelen dönüş trafiğine de izin verilecek, böylece saldırgana normalde engellenen VLAN'daki cihazlarla iletişim kurma yeteneği sağlanacaktır.

**VLAN Saldırılarını Azaltma** – VLAN atlaması ve VLAN çift etiketleme saldırıları, aşağıdaki trunk güvenliği yönergeleri uygulanarak önlenabilir:

- Tüm erişim bağlantı noktalarında trunk devre dışı bırakma.
- Trunk bağlantılarında otomatik trunking işlevini devre dışı bırakın, böylece trunklar manuel olarak etkinleştirilmelidir.
- Yerel VLAN'ın yalnızca trunk bağlantıları için kullanıldığından emin olun.

## DHCP Mesajları

DHCP sunucuları, istemcilere IP adresi, alt ağ maskesi, varsayılan ağ geçidi, DNS sunucuları ve daha fazlasını içeren IP yapılandırma bilgilerini dinamik olarak sağlar. İstemci ile sunucu arasındaki DHCP ileti alışverişi sırasının bir incelemesi şeklinde gösterilmiştir.



## DHCP Atakları

İki tür DHCP saldırısı vardır; DHCP açlığı (**DHCP Starvation**) ve DHCP sahtekarlığı (**DHCP Spoofing Attack**). Her iki saldırı da DHCP gözetlemesi (DHCP snooping) uygulanarak azaltılır.

**DHCP Starvation Attack** – Bu saldırının amacı, istemcileri ağa bağlamak için bir DoS atağı oluşturmaktır. DHCP açlık saldırıları için Gobbler veya Yersinia gibi bir saldırı aracı gerekir. Bu araçlar kiralanabilir IP adreslerinin tümünü kiralamaya çalışır. Bu işi, sahte MAC adresleri ile DHCP keşif mesajları oluşturarak yaparlar.

**DHCP Spoofing Attack** – Bu, sahte bir DHCP sunucusu ağına bağlandığında ve yasal istemcilere yanlış IP yapılandırma parametreleri sağladığında oluşur. Sahte bir sunucu aşağıdakiler de dahil olmak üzere çeşitli yanıltıcı bilgiler sağlayabilir;

- **Wrong default gateway** – Sahte sunucu, ortadaki adam saldırısı oluşturmak için geçersiz bir ağ geçidi veya ana bilgisayarlarının IP adresini sağlar. Davetsiz misafir ağ üzerinden veri akışına müdahale ettiği için bu tamamen tespit edilemez.
- **Wrong DNS server** – Sahte sunucu, kullanıcıyı kötü amaçlı bir web sitesine yönlendiren yanlış bir DNS sunucu adresi sağlar.
- **Wrong IP address** – Sahte sunucu, DHCP istemcisine etkili bir şekilde DoS saldırısı oluşturan geçersiz bir IP adresi sağlar.

## ARP Atakları

- Ana bilgisayarlar, hedef IP adresine sahip bir ana bilgisayarın MAC adresini belirlemek için ARP istekleri yayınlar. Alt ağdaki tüm ana bilgisayarlar ARP isteğini alır ve işler. ARP isteğinde eşleşen IP adresine sahip ana bilgisayar bir ARP yanıtı gönderir.
- Bir istemci gratuitous ARP Yanıtı gönderebilir. Alt ağdaki diğer ana bilgisayarlar, ARP'de bulunan MAC adresini ve IP adresini ARP tablolarında saklar.
- Saldırgan, bir anahtara sahte bir MAC adresi içeren gratuitous ARP mesajı gönderebilir ve anahtar MAC tablosunu buna göre güncelleyecektir. Tipik bir saldırıda, bir tehdit aktörü, tehdit aktörünün MAC adresi ve varsayılan ağ geçidinin IP adresi ile ağdaki diğer ana bilgisayarlara istenmeyen bir ARP yanıtları göndererek, ortadaki bir adamı (MITM) etkili bir şekilde kurar.
- İnternette ARP ortadaki adam saldırıları oluşturmak için birçok araç vardır (Ettercap).
- IPv6, Katman 2 adres çözümlemesi için ICMPv6 Komşu Bulma Protokolü'nü kullanır. IPv6, IPv6'nın sahte bir ARP yanıtını önleme yöntemine benzer şekilde Komşu Reklamı kimlik sahtekarlığını azaltmak için stratejiler içerir.
- ARP kimlik sahtekarlığı ve ARP zehirlenmesi, Dinamik ARP Denetimi (DAI-Dynamic ARP Inspection) uygulanarak azaltılır.

## Address Sahtekarlığı Atakları

- IP adresi sahteciliği, bir tehdit aktörünün alt ağdaki başka bir aygıtın geçerli bir IP adresini ele geçirmesi veya rastgele bir IP adresi kullanmasıdır. IP adresi sahteciliğini azaltmak, özellikle IP'nin ait olduğu bir alt ağ içinde kullanıldığında hafifletilmesi zordur.

- MAC adresi kimlik sahtekarlığı saldırıları, tehdit aktörleri bilgisayarların MAC adreslerini, hedef bilgisayarın bilinen başka bir MAC adresiyle eşleştirecek şekilde değiştirildiğinde ortaya çıkar. Anahtar, geçerli MAC tablosu girişinin üzerine yazar ve MAC adresini yeni bağlantı noktasına atar. Daha sonra istemeden hedef ana bilgisayar için hedeflenen çerçeveleri saldıran ana bilgisayara iletir.
- Hedef ana bilgisayar trafik gönderdiğinde, anahtar MAC adresini orijinal bağlantı noktasına yeniden hizalayarak hatayı düzeltir. Anahtarın bağlantı noktası atamasını doğru durumuna döndürmesini durdurmak için tehdit aktörü, anahtara sürekli olarak çerçeve gönderecek bir program veya komut dosyası oluşturabilir, böylece anahtar yanlış veya sahte bilgileri korur. (hping, scapy)
- Katman 2'de, bir anahtarın MAC adreslerinin kaynağını doğrulamasına izin veren bir güvenlik mekanizması yoktur, bu da kimlik sahtekarlığına karşı bu kadar savunmasız kılan şeydir.
- IP ve MAC adres sahteciliği, IP Source Guard (IPSG) uygulanarak azaltılabilir.

## STP Atakları

- Ağ saldırganları, kök köprüyü (root bridge) taklit ederek ve bir ağın topolojisini değiştirerek bir saldırı gerçekleştirmek için Spanning Tree Protocol (STP) manipüle edebilir. Saldırganlar daha sonra anahtarlanan etki alanı için tüm trafiği yakalayabilir.
- Bir STP manipülasyon saldırısı gerçekleştirmek için, saldırgan STP'nin yeniden hesaplamalarını zorlayacak yapılandırma ve topoloji değişiklikleri içeren STP köprü protokolü veri birimlerini (BPDU'lar) yayınlar. Saldıran bilgisayarın gönderdiği BPDU'lar kök köprü olarak seçilmek için daha küçük köprü önceliği ilan eder.
- Bu STP saldırısı, tüm erişim bağlantı noktalarına BPDU Guard uygulanarak azaltılır.

## CDP Keşfi

Cisco Keşif Protokolü (CDP) tescilli bir Katman 2 bağlantı keşfi protokolüdür. Varsayılan olarak tüm Cisco cihazlarında etkindir. Ağ yöneticileri, ağ aygıtlarını yapılandırmaya ve sorun gidermeye yardımcı olması için CDP'yi kullanır. CDP bilgileri, periyodik, şifrelenmemiş, kimliği doğrulanmamış yayınlarda CDP özellikli bağlantı noktalarına gönderilir. CDP bilgileri cihazın IP adresini, IOS yazılım sürümünü, platformu, yetenekleri ve yerel VLAN'ı içerir. CDP mesajını alan aygıt CDP veri tabanını günceller.

CDP sömürsünü azaltmak için, aygıtlarda veya bağlantı noktalarında CDP kullanımını sınırlayın. Örneğin, güvenilmeyen aygıtlara bağlanan kenar bağlantı noktalarında CDP'yi devre dışı bırakın.

- Bir aygıtta CDP'yi genel olarak devre dışı bırakmak için, **no cdp run** global yapılandırma modu komutunu kullanın. CDP'yi genel olarak etkinleştirmek için **cdp run** global yapılandırma komutunu kullanın.
- Bir bağlantı noktasında CDP'yi devre dışı bırakmak için, **no cdp enable** arabirimi yapılandırma komutunu kullanın. Bir bağlantı noktasında CDP'yi etkinleştirmek için **cdp enable** arabirimi yapılandırma komutunu kullanın.

# Port Güvenliđi Yapılandırması

## Kullanılmayan Bağlantı Noktalarını Güvenli Hale Getirin

Katman 2 saldırıları, bilgisayar korsanlarının gerçekleştirmesi en kolay saldırılardandır, ancak bu tehditler bazı ortak Katman 2 çözümleriyle de hafifletilebilir.

- Anahtar üretim kullanımı için konuşlandırılmadan önce tüm anahtar bağlantı noktaları (arabirimler) sabitlenmelidir. Bir bağlantı noktasının nasıl sabitlendiđi, işlevine bağlıdır.
- Birçok yöneticinin ađı yetkisiz erişimden korumaya yardımcı olması için kullandığı basit bir yöntem, bir anahtardaki kullanılmayan tüm bağlantı noktalarını devre dışı bırakmaktır. Kullanılmayan her bağlantı noktasına gidin ve Cisco IOS **shutdown** komutunu verin. Bir bağlantı noktasının daha sonra yeniden etkinleştirilmesi gerekiyorsa, **no shutdown** komutu ile etkinleştirilebilir.

Bir bağlantı noktası aralıđını yapılandırmak için **interface range** komutunu kullanın.

```
Switch (config) # interface range type module/first-number – last-number
```

## MAC Adres Tablosu Saldırılarını Azaltma

MAC adres tablosu taşma saldırılarını önlemenin en basit ve etkili yöntemi bağlantı noktası güvenliđini (Port Security) etkinleştirmektir.

- Bağlantı noktası güvenliđi, bir bağlantı noktasında izin verilen geçerli MAC adresi sayısını sınırlar. Yöneticinin bir bağlantı noktası için MAC adreslerini manuel olarak yapılandırmasına veya anahtarın sınırlı sayıda MAC adresini dinamik olarak öğrenmesine izin vermesine olanak tanır. Bağlantı noktası güvenliđi ile yapılandırılan bir bağlantı noktası bir çerçeve aldıđında, çerçevenin kaynak MAC adresi, bağlantı noktasında el ile yapılandırılan veya dinamik olarak öğrenilen güvenli kaynak MAC adresleri listesiyle karşılaştırılır.
- Bir bağlantı noktasındaki izin verilen MAC adresi sayısını bir taneyle sınırlandırarak, bağlantı noktası güvenliđi ađa yetkisiz erişimi kontrol etmek için kullanılabilir.

## Bağlantı Noktası Güvenliğini Etkinleştirme

Bağlantı noktası güvenliği, **switchport port-security** arabirim yapılandırma komutuyla etkinleştirilir.

Örnekte, **switchport port-security** komutunun reddedildiğine dikkat edin. Bunun nedeni, bağlantı noktası güvenliğinin yalnızca elle yapılandırılmış erişim (access) bağlantı noktalarında veya elle yapılandırılmış trunk bağlantı noktalarında yapılandırılabilmesidir. Varsayılan olarak, Katman 2 anahtar bağlantı noktaları dinamik otomatik- dynamic auto olarak ayarlanır. Bu nedenle, örnekte, bağlantı noktası **switchport mode access** arabirim yapılandırma komutuyla yapılandırılır.

```
S1(config)# interface f0/1
S1(config-if)# switchport port-security
Command rejected: FastEthernet0/1 is a dynamic port.
S1(config-if)# switchport mode access
S1(config-if)# switchport port-security
S1(config-if)# end
S1#
```

## Bağlantı Noktası Güvenliğini Etkinleştirme

FastEthernet 0/1 için geçerli bağlantı noktası güvenlik ayarlarını görüntülemek için **show port-security interface** komutunu kullanın.

- Bağlantı noktası güvenliğinin nasıl etkinleştirildiğine, ihlal modunun kapatma (shutdown) ve maksimum MAC adresi sayısının 1 olduğuna dikkat edin.
- Bağlantı noktasına bir aygıt bağlıysa, anahtar otomatik olarak aygıtın MAC adresini güvenli bir MAC olarak ekler. Bu örnekte, bağlantı noktasına hiçbir aygıt bağlı değildir.

Not: Etkin bir bağlantı noktası switchport bağlantı noktası güvenlik komutuyla yapılandırılırsa ve bu bağlantı noktasına birden fazla aygıt bağlanırsa, bağlantı noktası hata devre dışı – error disabled durumuna geçer.

```
S1# show port-security interface f0/1
Port Security           : Enabled
Port Status              : Secure-shutdown
Violation Mode           : Shutdown
Aging Time               : 0 mins
Aging Type               : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses    : 1
Total MAC Addresses      : 0
Configured MAC Addresses : 0
Sticky MAC Addresses     : 0
Last Source Address:Vlan : 0000.0000.0000:0
Security Violation Count : 0
S1#
```

## MAC Adreslerini Sınırlama ve Öğrenme

Bir bağlantı noktasında izin verilen maksimum MAC adresi sayısını ayarlamak için aşağıdaki komutu kullanın:

```
Switch (config-if) # switchport port-security maximum value
```

- Varsayılan bağlantı noktası güvenlik değeri 1'dir.
- Yapılandırılacak maksimum güvenli MAC adresi sayısı, anahtara ve IOS'a bağlıdır.
- Bu örnekte, maksimum 8192'dir.

```
S1(config)# interface f0/1
S1(config-if)# switchport port-security maximum ?
<1-8192> Maximum addresses
S1(config-if)# switchport port-security maximum
```

Anahtar, güvenli bir bağlantı noktasındaki MAC adresleri hakkında üç yoldan birini öğrenmek üzere yapılandırılabilir:

1. **El ile (Manuel) Yapılandırılmış:** Yönetici, bağlantı noktasındaki her güvenli MAC adresi için aşağıdaki komutu kullanarak statik bir MAC adresini / adreslerini el ile yapılandırır:  

```
Switch (config-if) # switchport port-security mac-address mac-address
```
2. **Dinamik Olarak Öğrenme – Dynamically Learned:** switchport port-security komutu girildiğinde, bağlantı noktasına bağlı aygıt için geçerli kaynak MAC otomatik olarak korunur ancak çalışan yapılandırmaya eklenmez. Anahtar yeniden başlatılırsa, bağlantı noktasının cihazın MAC adresini yeniden öğrenmesi gerekir.
3. **Dinamik Olarak Öğrenme – Yapıştırma – Dynamically Learned – Sticky:** Yönetici, anahtarın MAC adresini dinamik olarak öğrenmesini ve aşağıdaki komutu kullanarak çalışan yapılandırmaya “yapışmasını” sağlayabilir:

```
Switch (config-if) # switchport port-security mac-address sticky
```

Çalışan yapılandırmanın kaydedilmesi, dinamik olarak öğrenilen MAC adresini NVRAM'a kayıt edecektir.

Örnek, FastEthernet 0/1 için eksiksiz bir bağlantı noktası güvenlik yapılandırması gösterir.

- Yönetici en fazla 4 MAC adresi belirtir, bir güvenli MAC adresini manuel olarak yapılandırır ve ardından bağlantı noktasını maksimum 4 güvenli MAC adresine kadar ek güvenli MAC adresini dinamik olarak öğrenecek şekilde yapılandırır.
- Yapılandırmayı doğrulamak için **show port-security interface** ve **show port-security address** komutunu kullanın.

```

S1(config)# interface fa0/1
S1(config-if)# switchport mode access
S1(config-if)# switchport port-security
S1(config-if)# switchport port-security maximum 4
S1(config-if)# switchport port-security mac-address aaaa.bbbb.1234
S1(config-if)# switchport port-security mac-address sticky
S1(config-if)# end
S1# show port-security interface fa0/1
Port Security                : Enabled
Port Status                  : Secure-up
Violation Mode               : Shutdown
Aging Time                   : 0 mins
Aging Type                   : Absolute
SecureStatic Address Aging   : Disabled
Maximum MAC Addresses        : 4
Total MAC Addresses          : 1
Configured MAC Addresses     : 1
Sticky MAC Addresses         : 0
Last Source Address:Vlan    : 0000.0000.0000:0
Security Violation Count     : 0
S1# show port-security address
                Secure Mac Address Table
-----
Vlan    Mac Address      Type                Ports    Remaining Age
(mins)
-----
   1    aaaa.bbbb.1234    SecureConfigured    Fa0/1    -
-----
Total Addresses in System (excluding one mac per port)  : 0
Max Addresses limit in System (excluding one mac per port) : 8192

S1#

```

## Port Güvenliği Yaşlanması

Bağlantı noktası güvenlik yaşlandırması, bir bağlantı noktasındaki statik ve dinamik güvenli adreslerin yaşlanma süresini ayarlamak için kullanılabilir ve bağlantı noktası başına iki tür yaşlanma desteklenir:

- **Kesin (Absolute)** – Bağlantı noktasındaki güvenli adresler, belirtilen yaşlanma süresinden sonra silinir.
- **Durgunluk (Inactivity)** – Bağlantı noktasındaki güvenli adresler, belirtilen bir süre boyunca etkin olmadıklarında silinir.
- Mevcut güvenli MAC adreslerin el ile silmeden güvenli bir bağlantı noktasındaki güvenli MAC adreslerini kaldırmak için yaşlanmayı kullanın.

Statik olarak yapılandırılmış güvenli adreslerin yaşlanması her port için etkinleştirilebilir veya devre dışı bırakılabilir.

Güvenli bağlantı noktası için statik yaşlanmayı etkinleştirmek veya devre dışı bırakmak veya yaşlanma zamanını veya türünü ayarlamak için switchport port-security aging komutunu kullanın.

```
Switch(config-if)# switchport port-security aging {static | time time | type {absolute | inactivity}}
```

Örnekte, yaşlanma türünü 10 dakika boyunca hiçbir işlem yapılmadığında yapılandıran bir switch gösterilmektedir.

Show port-security komutu ile değişiklikler onaylanır.

```
S1(config)# interface fa0/1
S1(config-if)# switchport port-security aging time 10
S1(config-if)# switchport port-security aging type inactivity
S1(config-if)# end
S1# show port-security interface fa0/1
Port Security                : Enabled
Port Status                   : Secure-shutdown
Violation Mode                 : Restrict
Aging Time                    : 10 mins
Aging Type                    : Inactivity
SecureStatic Address Aging    : Disabled
Maximum MAC Addresses         : 4
Total MAC Addresses           : 1
Configured MAC Addresses      : 1
Sticky MAC Addresses          : 0
Last Source Address:Vlan      : 0050.56be.e4dd:1
Security Violation Count      : 1
```

## Port Güvenliği İhlali Modları

Bir bağlantı noktasına bağlı bir aygıtın MAC adresi güvenli adresler listesinden farklıysa, bir bağlantı noktası ihlali oluşur ve bağlantı noktası hata devre dışı durumuna (error-disable state) girer.

- Bağlantı noktası güvenlik ihlali modunu ayarlamak için aşağıdaki komutu kullanın:

```
Switch(config-if) # switchport port-security violation {shutdown | restrict | protect}
```

Aşağıdaki tablo, bir anahtarın yapılandırılmış ihlal moduna göre nasıl tepki verdiğini gösterir:

| Mode                      | Description                                                                                                                                                                                                                                                                                                                    |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Shutdown (default)</b> | Bağlantı noktası derhal devre dışı durumuna (error-disable) geçer, bağlantı noktası LED'ini kapatır ve bir sistem günlüğü iletisi gönderir. İhlal sayacını artırır. Güvenli bir bağlantı noktası hata devre dışı durumundayken, yöneticinin shutdown ve no shutdown komutlarını girerek portu yeniden etkinleştirmesi gerekir. |
| <b>Restrict</b>           | Bağlantı noktası, maksimum değerin altına düşmek veya maksimum değeri artırmak için yeterli sayıda güvenli MAC adresi kaldırana kadar, kaynak adresleri bilinmeyen paketleri bırakır. Bu mod, Güvenlik ihlali sayacının artmasına neden olur ve bir sistem günlüğü iletisi oluşturur.                                          |
| <b>Protect</b>            | Bu, güvenlik ihlali modlarının en az güvenli olanıdır. Bağlantı noktası, maksimum değerin altına düşmek veya maksimum değeri artırmak için yeterli sayıda güvenli MAC adresi kaldırana kadar bilinmeyen MAC kaynak adreslerine sahip paketleri bırakır. Hiçbir sistem günlüğü mesajı gönderilmez.                              |

Örnekte, bir yöneticinin güvenlik ihlali “Restrict-Kısıtla” olarak değiştirdiği gösterilmektedir.

**Show port-security interface** komutunun çıktısı, değişikliğin yapıldığını onaylar.

```

S1(config)# interface f0/1
S1(config-if)# switchport port-security violation restrict
S1(config-if)# end
S1#
S1# show port-security interface f0/1
Port Security                : Enabled
Port Status                  : Secure-shutdown
Violation Mode                : Restrict
Aging Time                   : 0 mins
Aging Type                   : Absolute
SecureStatic Address Aging   : Disabled
Maximum MAC Addresses        : 4
Total MAC Addresses          : 1
Configured MAC Addresses     : 1
Sticky MAC Addresses         : 0
Last Source Address:Vlan     : 0050.56be.e4dd:1
Security Violation Count     : 1
S1#

```

## Hata devre dışı durumundaki (error-disabled state) bağlantı noktaları

Bir bağlantı noktası kapatıldığında ve hata devre dışı bırakıldığında, bu bağlantı noktasında trafik gönderilmez veya alınmaz.

Aşağıdaki örnekte gösterildiği gibi, konsolda bir dizi bağlantı noktası güvenliği ile ilgili mesaj görüntülenir.

Not: Bağlantı noktası protokolü ve bağlantı durumu down olarak değiştirilir ve bağlantı noktası LED'i söner.

```
*Sep 20 06:44:54.966: %PM-4-ERR_DISABLE: psecure-violation error detected on Fa0/18, putting Fa0/18 in err-disable state
*Sep 20 06:44:54.966: %PORT_SECURITY-2-PSECURE_VIOLATION: Security violation occurred, caused by MAC address 000c.292b.4c75 on port FastEthernet0/18.
*Sep 20 06:44:55.973: %LINEPROTO-5-PPDOWN: Line protocol on Interface FastEthernet0/18, changed state to down
*Sep 20 06:44:56.971: %LINK-3-UPDOWN: Interface FastEthernet0/18, changed state to down
```

- Örnekte, show interface komutu bağlantı noktası durumunu error-disabled olarak tanımlar. Show port-security interface komutunun çıktısı artık bağlantı noktası durumunu secure-shutdown olarak gösterir. Güvenlik ihlali sayacı 1 artar.
- Yönetici, güvenlik ihlaline neyin neden olduğunu belirlemelidir. Yetkisiz bir aygıt güvenli bir bağlantı noktasına bağlanırsa, bağlantı noktası yeniden etkinleştirilmeden önce güvenlik tehdidi ortadan kaldırılır.
- Bağlantı noktasını yeniden etkinleştirmek için, önce **shutdown** komutunu kullanın, ardından **no shutdown** komutunu kullanın.

## Bağlantı Noktası Güvenliğini Doğrulama

Bir anahtarda bağlantı noktası güvenliğini yapılandırdıktan sonra, bağlantı noktası güvenliğinin doğru ayarlandığını doğrulamak için her arabirimi ve statik MAC adreslerinin doğru yapılandırıldığından emin olun.

Anahtarın bağlantı noktası güvenlik ayarlarını görüntülemek için **show port-security** komutunu kullanın.

- Örnekte, izin verilen maksimum 1 olduğu ve ihlal modunun kapatma olduğu 24 portun da **switchport port-security** komutuyla yapılandırıldığını gösterir.
- Bağlı cihaz yok, bu nedenle her arabirim için CurrentAddr (Sayaç) 0.

```

S1# show port-security
Secure Port  MaxSecureAddr  CurrentAddr  SecurityViolation  Security Action
          (Count)         (Count)         (Count)
-----
    Fa0/1           1           0           0           Shutdown
    Fa0/2           1           0           0           Shutdown
    Fa0/3           1           0           0           Shutdown
(output omitted)
    Fa0/24          1           0           0           Shutdown
-----

Total Addresses in System (excluding one mac per port)  : 0
Max Addresses limit in System (excluding one mac per port) : 4096
Switch#

```

Daha önce ve bu örnekte gösterildiği gibi, belirli bir arabirimin ayrıntılarını görüntülemek için **show port-security interace** komutunu kullanın.

```

S1# show port-security interface fastethernet 0/18
Port Security           : Enabled
Port Status             : Secure-up
Violation Mode          : Shutdown
Aging Time              : 0 mins
Aging Type              : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses   : 1
Total MAC Addresses     : 1
Configured MAC Addresses : 0
Sticky MAC Addresses    : 0
Last Source Address:Vlan : 0025.83e6.4b01:1
Security Violation Count : 0
S1#

```

MAC adreslerinin yapılandırmaya “yapıştığını” doğrulamak için FastEthernet 0/19 örneğinde gösterildiği gibi **show run** komutunu kullanın.

```

S1# show run | begin interface FastEthernet0/19
interface FastEthernet0/19
switchport mode access
switchport port-security maximum 10
switchport port-security
switchport port-security mac-address sticky
switchport port-security mac-address sticky 0025.83e6.4b02
(output omitted)
S1#

```

Tüm anahtar arabirimlerinde el ile yapılandırılan veya dinamik olarak öğrenilen tüm güvenli MAC adreslerini görüntülemek için, örnekte gösterildiği gibi **show port-security address** komutunu kullanın.

```
S1# show port-security address
```

```
Secure Mac Address Table
```

| Vlan | Mac Address    | Type          | Ports  | Remaining Age (mins) |
|------|----------------|---------------|--------|----------------------|
| 1    | 0025.83e6.4b01 | SecureDynamic | Fa0/18 | -                    |
| 1    | 0025.83e6.4b02 | SecureSticky  | Fa0/19 | -                    |

```
Total Addresses in System (excluding one mac per port) : 0
```

```
Max Addresses limit in System (excluding one mac per port) : 8192
```

```
S1#
```

# VLAN Saldırılarını Önleme/Azaltma

## VLAN Saldırılarının İncelemesi

Bir VLAN atlama saldırısı üç yoldan biriyle başlatılabilir;

- Anahtarın trunk moduna girmesine neden olmak için saldıran ana bilgisayardan DTP iletilerini taklit edilir. Buradan, saldırgan hedef VLAN ile etiketlenmiş trafiği gönderebilir ve anahtar daha sonra paketleri hedefe iletir.
- Bir sahte (spoof) anahtarın tanıtılması ve trunk etkinleştirilmesi. Saldırgan daha sonra kurban anahtarındaki tüm VLAN'lara sahte anahtarından erişebilir.
- Başka bir VLAN atlamalı saldırısı türü, çift etiketleme (veya çift kapsüllenmiş çerçeve) saldırısıdır. Bu saldırı, çoğu anahtardaki donanımın çalışma şekline göre yararlanır.

## VLAN Atlama Saldırılarını Azaltma Adımları

VLAN atlama saldırılarını azaltmak için aşağıdaki adımları kullanın:

Adım 1: **switchport mode access** arabirim yapılandırma komutunu kullanarak trunk dışı bağlantı noktalarındaki DTP (otomatik trunk) görüşmelerini devre dışı bırakın.

Adım 2: Kullanılmayan bağlantı noktalarını devre dışı bırakın ve kullanılmayan bir VLAN'a yerleştirin.

Adım 3: **switchport mode trunk** komutunu kullanarak bir trunk bağlantı noktasını el ile (manuel) etkinleştirin.

Adım 4: **switchport nonegotiate** komutunu kullanarak trunk bağlantı noktalarındaki DTP (otomatik trunk) görüşmelerini devre dışı bırakın.

Adım 5: **switchport trunk native vlan vlan\_number** komutunu kullanarak yerel VLAN'ı VLAN 1 dışında bir VLAN'a ayarlayın.

```
S1(config)# interface range fa0/1 - 16
S1(config-if-range)# switchport mode access
S1(config-if-range)# exit
S1(config)#
S1(config)# interface range fa0/17 - 20
S1(config-if-range)# switchport mode access
S1(config-if-range)# switchport access vlan 1000
S1(config-if-range)# exit
S1(config)#
S1(config)# interface range fa0/21 - 24
S1(config-if-range)# switchport mode trunk
S1(config-if-range)# switchport nonegotiate
S1(config-if-range)# switchport trunk native vlan 999
S1(config-if-range)# end
S1#
```

# DHCP Saldırılarını Azaltma

## DHCP Saldırısının İncelemesi

DHCP açlık saldırısının amacı, istemcileri ağa bağlamak için bir Hizmet Reddi (DoS) oluşturmak üzere Gobbler veya Yersinia gibi bir saldırı aracını kullanır.

Gobbler gönderilen her DHCP isteği için benzersiz bir kaynak MAC adresi kullandığından DHCP açlık saldırılarının bağlantı noktası güvenliği kullanılarak etkili bir şekilde azaltılabileceğini hatırlayın. Ancak, DHCP kimlik sahtekarlığı saldırılarını azaltmak daha fazla koruma gerektirir.

Gobbler, gerçek arayüz MAC adresini kaynak Ethernet adresi olarak kullanacak şekilde yapılandırılabilir, ancak DHCP yükünde farklı bir Ethernet adresi belirtebilir. Bu, kaynak MAC adresi yasal olacağından bağlantı noktası güvenliğini etkisiz hale getirir.

DHCP kimlik sahtekarlığı saldırıları, güvenilen bağlantı noktalarında DHCP gözetleme (DHCP snooping) kullanılarak azaltılabilir.

## DHCP Gözetimi – Snooping

DHCP Gözetleme, güvenilmeyen bağlantı noktalarındaki DHCP iletilerini ve hız sınırlarıyla DHCP trafiğini filtreler.

- Yönetim kontrolü altındaki cihazlar (örn. Anahtarlar, yönlendiriciler ve sunucular) güvenilir kaynaklardır.
- Güvenilen arabirimler (örn. Trunk bağlantıları, sunucu bağlantı noktaları) açıkça güvenilir (trust) olarak yapılandırılmalıdır.
- Ağ dışındaki cihazlar ve tüm erişim portları genellikle güvenilmeyen kaynaklar (untrust) olarak değerlendirilir.

Güvenilmeyen bir bağlantı noktasındaki bir aygıtın kaynak MAC adresini ve DHCP sunucusu tarafından o aygıta atanan IP adresini içeren bir DHCP tablosu oluşturulur.

- MAC adresi ve IP adresi birbirine bağlıdır.
- Bu nedenle, bu tabloya DHCP gözetleme bağlama tablosu (DHCP snooping binding table) denir.

## DHCP Gözetleme Bağlama Tablosu

DHCP gözetlemeyi etkinleştirmek için aşağıdaki adımları kullanın:

Adım 1: **ip dhcp snooping** genel yapılandırma komutunu kullanarak DHCP gözetlemeyi etkinleştirin.

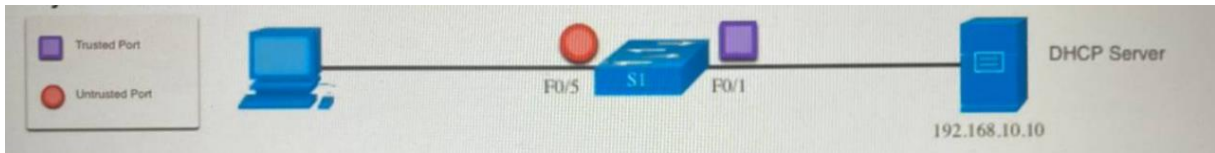
Adım 2: Güvenilir bağlantı noktalarında **ip dhcp snooping trust** arabirim yapılandırma komutunu kullanın.

Adım 3: Güvenilmeyen arabirimlerde, **ip dhcp snooping limit rate** arabirim yapılandırma komutu kullanılarak alınabilen DHCP keşif mesajlarının sayısını sınırlayın.

Adım 4: **ip dhcp snooping vlan** genel yapılandırma komutunu kullanarak VLAN veya bir dizi VLAN ile DHCP gözetlemeyi etkinleştirin.

## DHCP Snooping Yapılandırma Örneği

Güvenilen ve güvenilmeyen bağlantı noktalarına sahip DHCP gözetleme örneği topolojisine bakınız.



- DHCP gözetlemesi ilk olarak S1'de etkinleştirilir.
- DHCP sunucusunun bağlı olduğu port güvenilir olarak yapılandırılır.
- F0/5 ila F0/24 güvenilir değildir ve bu nedenle hız saniyede altı paketle sınırlıdır.
- Son olarak, DHCP gözetlemesi VLAN 5, 10, 50, 51 ve 52'de etkinleştirilir.

```
S1(config)# ip dhcp snooping
S1(config)# interface f0/1
S1(config-if)# ip dhcp snooping trust
S1(config-if)# exit
S1(config)# interface range f0/5 - 24
S1(config-if-range)# ip dhcp snooping limit rate 6
S1(config-if)# exit
S1(config)# ip dhcp snooping vlan 5,10,50-52
S1(config)# end
S1#
```

DHCP gözetleme ayarlarını doğrulamak için **show ip dhcp snooping** ayrıcalıklı EXEC komutunu kullanın.

DHCP bilgisi alan istemcileri görüntülemek için **show ip dhcp snooping binding** komutunu kullanın.

**Not:** DHCP gözetlemesi Dinamik ARP Denetimi (DAI) için de gereklidir.

```
S1# show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
5,10,50-52
DHCP snooping is operational on following VLANs:
none
DHCP snooping is configured on the following L3 Interfaces:
Insertion of option 82 is enabled
  circuit-id default format: vlan-mod-port
  remote-id: 0cd9.96d2.3f80 (MAC)
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Verification of giaddr field is enabled
DHCP snooping trust/rate is configured on the following Interfaces:
Interface                Trusted    Allow option    Rate limit (pps)
-----
FastEthernet0/1          yes       yes             unlimited
  Custom circuit-ids:
FastEthernet0/5          no        no              6
  Custom circuit-ids:
FastEthernet0/6          no        no              6
  Custom circuit-ids:
S1# show ip dhcp snooping binding
MacAddress                IPAddress            Lease(sec)  Type           VLAN  Interface
-----
00:03:47:B5:9F:AD        192.168.10.10       193185     dhcp-snooping  5     FastEthernet0/5
```

# ARP Saldırılarını Azaltma

## Dynamic ARP Inspection – Dinamik ARP Denetimi

Tipik bir ARP saldırısında, bir tehdit aktörü, tehdit aktörünün MAC Adresi ve varsayılan ağ geçidinin IP adresi ile alt ağdaki diğer ana bilgisayarlara istenmeyen ARP yanıtları gönderebilir. ARP kimlik sahtekarlığını ve bunun sonucunda ortaya çıkan ARP zehirlenmesini önlemek için, bir anahtar yalnızca geçerli ARP isteklerinin ve yanıtlarının iletildiğinden emin olmalıdır.

Dinamik ARP denetimi (DAI), DHCP gözetleme gerektirir ve ARP saldırılarını önlemeye yardımcı olur:

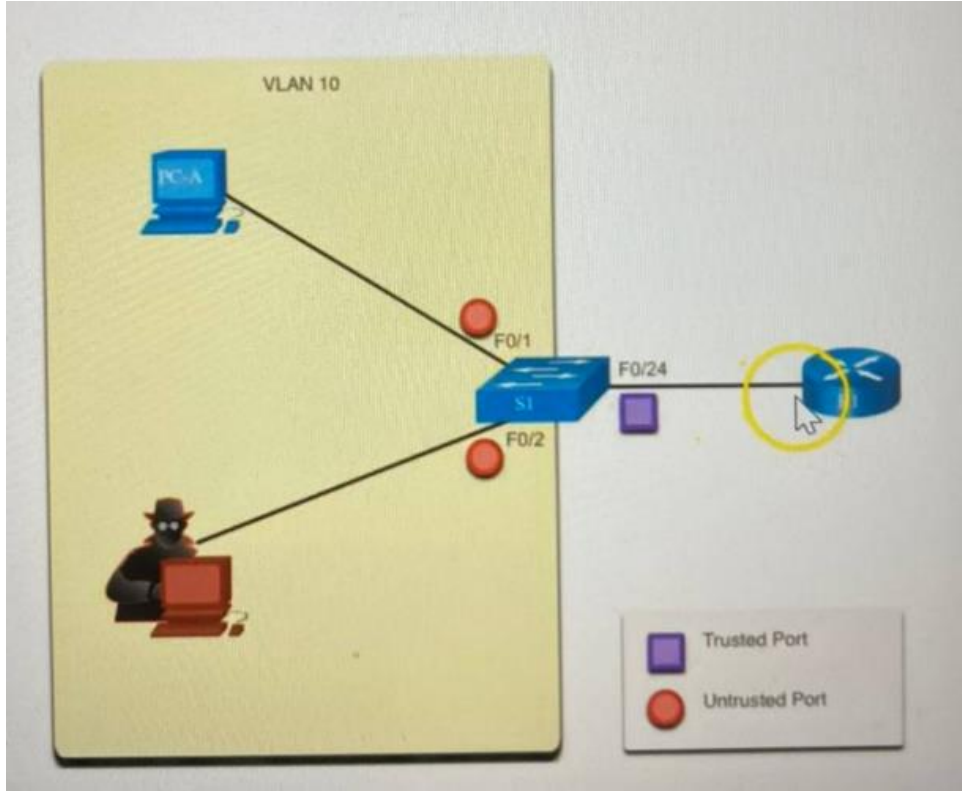
- Geçersiz veya gereksiz ARP yanıtlarını aynı VLAN'daki diğer bağlantı noktalarına aktarmamak.
- Güvenilmeyen bağlantı noktalarındaki tüm ARP isteklerini ve yanıtlarını engelleme.
- Her yakalanan paketi geçerli bir IP-MAC bağlaması için doğrulama.
- ARP zehirlenmesini önlemek için geçersiz gelen ARP Yanıtlarını düşürme ve günlüğe kaydetme.
- ARP paketlerinin yapılandırılmış DAI sayısı aşılsa arayüz devre dışı bırakılır.

## DAI Uygulama Yönergeleri

ARP kimlik sahtekarlığı ve ARP zehirlenmesi olasılığını azaltmak için aşağıdaki DAI uygulama yönergelerini izleyin:

- Global yapılandırma modunda DHCP gözetlemeyi etkinleştirin.
- Seçili VLAN'larda DHCP gözetlemeyi etkinleştirin.
- Seçili VLAN'larda DAI'yı etkinleştirin.
- DHCP gözetleme ve ARP denetimi için güvenilir arayüzleri yapılandırın.

Genel olarak, tüm anahtar access bağlantı noktalarını güveniliriz olarak yapılandırmanız ve diğer anahtarlara bağlı trunk portları güvenilir yapılandırmanız önerilir.



## DAI Yapılandırma Örneği

Önceki topolojide S1, VLAN 10'daki iki kullanıcıyı birbirine bağlıyor. DAI, ARP kimlik sahtekarlığı ve ARP zehirlenme saldırılarına karşı hafifletecek şekilde yapılandırılacaktır.

- DHCP gözetleme etkinleştirildi çünkü DAI, DHCP gözetleme bağlama tablosunun çalışmasını gerektiriyor.
- Ardından, VLAN 10'daki bilgisayarlar için DHCP gözetleme ve ARP denetimi etkinleştirilir.
- Yönlendiriciye olan yukarı bağlantı noktasına güvenilir ve bu nedenle DHCP gözetleme ve ARP denetimi için güvenilir olarak yapılandırılır.

```
S1(config)# ip dhcp snooping
S1(config)# ip dhcp snooping vlan 10
S1(config)# ip arp inspection vlan 10
S1(config)# interface fa0/24
S1(config-if)# ip dhcp snooping trust
S1(config-if)# ip arp inspection trust
```

DAI ayrıca hem hedef hem de kaynak MAC ve IP adreslerini kontrol edecek şekilde yapılandırılabilir:

- **Destination MAC** – Ethernet başlığındaki hedef MAC adresini ARP gövdesindeki hedef MAC adresine göre kontrol eder.
- **Source MAC** – Ethernet başlığındaki kaynak MAC adresini ARP gövdesindeki gönderen MAC adresine göre kontrol eder.
- **IP address** – ARP gövdesinde, 0.0.0.0, 255.255.255.255 adresleri ve tüm IP çok noktaya yayın adresleri de dahil olmak üzere geçersiz ve beklenmeyen IP adresleri olup olmadığını kontrol eder.

**ip arp inspection validate {[src-mac] [dst-mac] [ip]}** global yapılandırma komutu, IP adresleri geçersiz olduğunda DAI'yi ARP paketlerini bırakacak şekilde yapılandırmak için kullanılır.

- ARP paketlerinin gövdesindeki MAC adresleri, Ethernet başlığında belirtilen adreslere eşleşmediğinde kullanılabilir.
- Aşağıdaki örnekte bir komutun nasıl yapılandırılabileceğine dikkat edin.
- Birden çok **ip arp inspection validate** komutu girilirse önceki komutun üzerine yazılır.
- Birden fazla doğrulama yöntemi eklemek için, bunları çıktıda gösterilenle aynı komut satırına girin.

```
S1(config)# ip arp inspection validate ?
dst-mac  Validate destination MAC address
ip       Validate IP addresses
src-mac  Validate source MAC address
S1(config)# ip arp inspection validate src-mac
S1(config)# ip arp inspection validate dst-mac
S1(config)# ip arp inspection validate ip
S1(config)# do show run | include validate
ip arp inspection validate ip
S1(config)# ip arp inspection validate src-mac dst-mac ip
S1(config)# do show run | include validate
ip arp inspection validate src-mac dst-mac ip
S1(config)#
```

110

# STP Saldırılarını Önleme

## PortFast ve BPDU Guard

Ağ saldırganlarının, kök köprüyü taklit ederek ve bir ağın topolojisini değiştirerek bir saldırı gerçekleştirmek için Kapsama Ağacı Protokolü (STP) değiştirebileceğini hatırlayın.

STP saldırılarını azaltmak için PortFast ve Bridge Protokolü Veri Birimi (BPDU) Korumasını kullanın:

### PortFast

- PortFast, bir bağlantı noktasını dinleme ve öğrenme durumlarını atlayarak engelleme durumunda derhal yönlendirme durumuna getirir.
- Tüm son kullanıcı erişim portlarına uygulanır.

### BPDU Guard

- BPDU Koruması, BPDU alan bir bağlantı noktasını hemen devre dışı bırakır.
- PortFast gibi, BPDU koruması da yalnızca uç aygıtlara bağlı arabirimlerde yapılandırılmalıdır.

## PortFast Yapılandırması

PortFast, erişim bağlantı noktalarının STP'nin birleşmesi için beklemesi gereken süreyi en aza indirmek için STP dinleme ve öğrenme durumlarını atlar.

- PortFast'ı yalnızca erişim portlarında etkinleştirin.
- İnter switch bağlantılarındaki PortFast, genişleyen bir ağaç döngüsü (loop) oluşturabilir.

PortFast şöyle etkinleştirilebilir:

- Arabirimde – **spanning tree portfast** arabirimi yapılandırma komutunu kullanın.
- Genel olarak – Tüm erişim bağlantı noktalarında PortFast'ı etkinleştirmek için **spanning-tree portfast default** genel yapılandırma komutunu kullanın.

```
S1(config)# interface fa0/1
S1(config-if)# switchport mode access
S1(config-if)# spanning-tree portfast
%Warning: portfast should only be enabled on ports connected to a single
host. Connecting hubs, concentrators, switches, bridges, etc... to this
interface when portfast is enabled, can cause temporary bridging loops.
Use with CAUTION
%Portfast has been configured on FastEthernet0/1 but will only
have effect when the interface is in a non-trunking mode.
S1(config-if)# exit
S1(config)# spanning-tree portfast default
%Warning: this command enables portfast by default on all interfaces. You
should now disable portfast explicitly on switched ports leading to hubs,
switches and bridges as they may create temporary bridging loops.
S1(config)# exit
```

PortFast'ın genel olarak etkin olup olmadığını doğrulamak için aşağıdakilerden birini kullanabilirsiniz:

- **show running-config | begin span** komutu
- **show spanning-tree summary** komutu

PortFast'ın bir arabirimde etkinleştirilip etkinleştirilmediğini doğrulamak için **show running-config interface type/number** komutunu kullanın.

**show spanning-tree interface type/number detail** komutu ayrıntılı doğrulama için kullanılabilir.

## BPDU Guard Yapılandırması

Bir erişim bağlantı noktası, yanlışlıkla veya bir kullanıcı erişim bağlantı noktasına yetkisiz bir anahtar bağladığında beklenmedik bir BPDU alabilir.

- BPDU Koruması etkinleştirilmiş bir erişim bağlantı noktasına bir BPDU alınırsa, bağlantı noktası hata devre dışı durumuna getirilir.
- Bu, bağlantı noktası kapatıldığında ya **errdisable recovery cause psecure\_violation** global komutuyla otomatik olarak düzeltilebilir ya da manuel olarak yeniden etkinleştirilmesi gerekir.

BPDU Guard şu şekilde etkinleştirilir:

- Arabirimde – **spanning-tree bpduguard enable** arabirim yapılandırma komutuyla.
- Genel olarak – **spanning-tree portfast bpduguard default** global yapılandırma komutu ile BPDU Guard tüm access portlarda etkinleştirilir.

```
S1(config)# interface fa0/1
S1(config-if)# spanning-tree bpduguard enable
S1(config-if)# exit
S1(config)# spanning-tree portfast bpduguard default
S1(config)# end
S1# show spanning-tree summary
Switch is in pvst mode
Root bridge for: none
Extended system ID          is enabled
Portfast Default             is enabled
Portfast BPDU Guard Default  is enabled
Portfast BPDU Filter Default is disabled
Loopguard Default            is disabled
EtherChannel misconfig guard is enabled
UplinkFast                   is disabled
BackboneFast                  is disabled
Configured Pathcost method used is short
(output omitted)
S1#
```